تقرير TP3 — إخفاء هوية بيانات إنترنت الأشياء والهوية ذاتية السيادة

ماستر إنترنت الأشياء والأمن السيبراني — جامعة الشهيد حمه لخضر، الوادي — السنة الجامعية 2027/2026

إعداد: Abderrazzak Aiba — Abdelhakim Berrim

ملخص. نعالج خطر تسرّب الحياة الخاصة في بيانات العدادات الذكية من زاويتين. في الجزء A نثبت أن حذف الأسماء لا يكفي: هجوم ربط بسيط أعاد التعرّف على 47.9% من العملاء، ثم نقيس كلفة k-anonymity (k = 2، 5، 10) والخصوصية التفاضلية (ε = 0.1، 1، 10) على الفائدة. في الجزء B نبني تدفّق هوية ذاتية السيادة كاملاً (did:key، شهادة موقّعة، إفصاح انتقائي، ربط بالحامل، حماية من إعادة الإرسال، إلغاء) يسمح لقفل ذكي بالتحقق من صفة واحدة دون الاتصال بالمُصدِر، ونقارنه بتسجيل الدخول المركزي OAuth 2.0. كل الشيفرة بلغة Python، و26 اختباراً آلياً ناجحاً، وكل نتيجة تُعاد بأمر موثّق في README.

1. الجزء A — إخفاء هوية بيانات العدادات الذكية

1.1 البيانات وتصنيف الأعمدة

استعملنا مجموعة **ElectricityLoadDiagrams20112014** (مستودع UCI، رخصة CC BY 4.0) لعملاء شركة كهرباء برتغالية، في نسختها الساعية المنشورة في أرشيف Monash على Zenodo (321 عميلاً، 2012–2014)، لأن الملف الأصلي (250 MB) تعذّر تحميله. احتفظنا بسنة 2014 و**313 عميلاً** متصلين طوال السنة (8760 ساعة لكل عميل)، والطاقة بالـ kWh = القيمة ÷ 4 لأن الأرشيف يجمع أربع قراءات kW لكل ساعة. كثير من هؤلاء العملاء مؤسسات لا منازل (الوسيط 1.26 GWh في السنة).

لا تحتوي البيانات على معلومات ديموغرافية، لذلك **ولّدنا** (بزرع ثابت 2026) اسماً وعمراً وجنساً ورمزاً بريدياً من 4 أرقام لكل عميل، وسجلاً عاماً ثانياً من 2000 ساكن (المالكون الـ313 و1687 آخرون) يمثّل قائمة انتخابية أو سجلاً بلدياً. أما الصفات الحساسة فمحسوبة من **القراءات الحقيقية**.

الفئة	الأعمدة	المعالجة
معرّفات مباشرة	`household_id`، `owner_name`	حذف كامل
أشباه معرّفات	`age`، `zip`، `sex`	تعميم وحذف سجلات (k-anonymity)
صفات حساسة	`annual_kwh`، `night_share`، `occupancy_profile`	تُنشر كما هي، أو كإحصاءات مشوّشة (DP)

جدول 1 — تصنيف الأعمدة. `occupancy_profile` نمط الإشغال المستنتج من شكل الاستهلاك (نهاري، ذروة مسائية، مسطّح).

1.2 هجوم الربط (Linkage attack)

حذفنا المعرّفات فقط (النشر «الساذج»)، ثم ربطنا الجدول بالسجل العام بالدالة `pandas.merge` على أشباه المعرّفات. يُعدّ السجل مُعاداً التعرّف عليه إذا طابق شخصاً واحداً فقط في السجل، وتُقاس الصحة بجدول حقيقة لا يراه المهاجم.

أشباه المعرّفات المستعملة	سجلات فريدة في الجدول المنشور	إعادة تعرّف صحيحة
zip	0	0 (0%)
age + sex	42	3 (1.0%)
age + zip	238	88 (28.1%)
age + zip + sex	**275 (87.9%)**	**150 (47.9%)**

جدول 2 — نتيجة هجوم الربط على 313 سجلاً. كل تطابق فريد كان صحيحاً (دقة 100%).

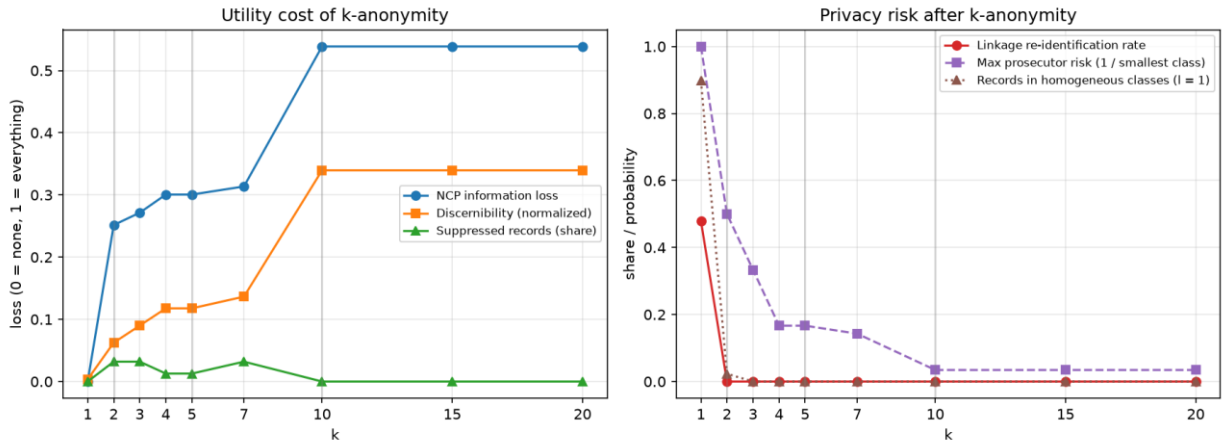
كل صفة وحدها ضعيفة، لكن اجتماعها يجعل 87.9% من السجلات فريدة. لا تتحوّل كلها إلى إعادة تعرّف لأن السجل العام يضم أشخاصاً آخرين يشاركونهم القيم نفسها. النتيجة ملموسة: يحصل المهاجم على اسم العميل مع استهلاكه السنوي ونمط إشغاله، أي متى يكون المكان فارغاً.

1.3 إخفاء الهوية بـ k-anonymity

المنهج (من بنانا): هرم تعميم لكل شبه معرّف: العمر (دقيق ← 5 سنوات ← 10 ← 20 ← *)، الرمز البريدي (حذف رقم في كل مستوى حتى *)، الجنس (دقيق ← *). شبكة التعميم صغيرة (5×5×2 = 50 عقدة)، لذلك نفحصها كلها ونختار العقدة ذات أقل خسارة معلومات **NCP** مع حذف 5% من السجلات كحدّ أقصى، وهي فكرة البحث الأمثل في أداة ARX. نقيس أيضاً مقياس التمييز **DM** ($\Sigma E^2/n^2$)، ثم نتحقق بشكل مستقل بمكتبة **pycanon** من k ومن l-diversity على نمط الإشغال، ونعيد هجوم الربط بعد تعميم السجل العام بالمستوى نفسه.

k	التعميم المختار	سجلات محذوفة	NCP	DM	k الفعلي (pycanon)	l	أقصى خطر	إعادة تعرّف
1 (أصلي)	بدون تعميم	0	0.000	0.004	1	1	1.00	150
2	عمر 5 سنوات، zip رقم واحد	10	0.252	0.062	2	1	0.50	0
5	عمر 20 سنة، zip رقم واحد	4	0.301	0.118	6	2	0.17	0
10	العمر محذوف، zip رقم واحد	0	0.539	0.340	29	3	0.03	0

جدول 3 — k-anonymity على 313 سجلاً. «أقصى خطر» = 1 / حجم أصغر فئة تكافؤ.



شكل 1 — يسار: كلفة الفائدة (NCP، DM، نسبة الحذف) بدلالة k. يمين: الخطر (نسبة إعادة التعرّف، أقصى خطر، السجلات في فئات متجانسة).

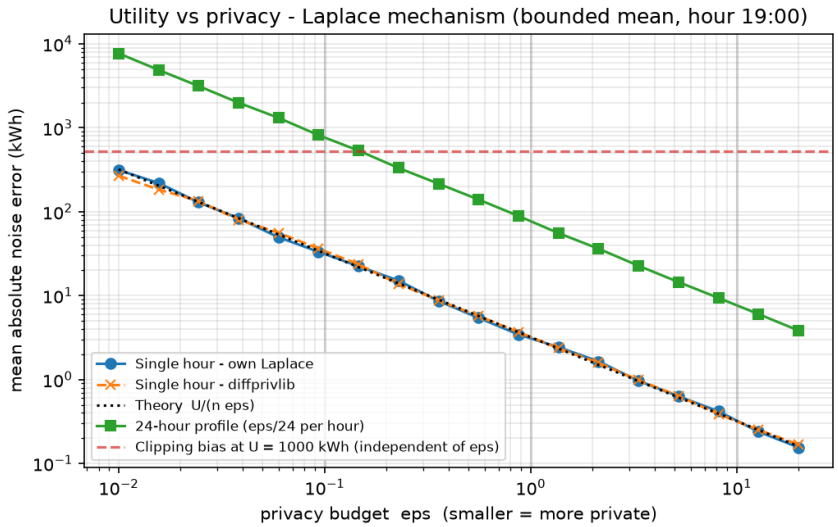
الملاحظات. (1) $k = 2$ تكفي لإيقاف هجوم الربط كلياً (من 150 إلى 0) بخسارة NCP قدرها 0.25. (2) تقفز الخسارة بين $k = 7$ و $k = 10$ من 0.31 إلى 0.54 لأن الهرم خشن: الخطوة التالية بعد فئات العشرين سنة هي حذف العمر كله. (3) يبقى الجنس دقيقاً في كل الحالات لأن تعميمه مكلف قليل الفائدة. (4) عند $k = 2$ يقع 2.3% من السجلات في فئات لها نمط إشغال واحد ($l = 1$)، فيعرف المهاجم صفتهم الحساسة دون أن يحدّد هويتهم (هجوم التجانس)، ولهذا قسنا l-diversity أيضاً.

1.4 الخصوصية التفاضلية (Differential Privacy)

الاستعلام: متوسط استهلاك العملاء في كل ساعة من اليوم، q_h. **الآلية (من بنائنا):** $\tilde{q}_h = q_h + \mathrm{Lap}(\Delta/\varepsilon)$ مع حد علوي عام **U = 1000 kWh** يُثبَّت مسبقاً ولا يُستخرج من البيانات، وعدد عملاء معلن $n = 313$، فالحساسية $\Delta = U/n = 3.19$ kWh. قارنّا تنفيذنا بالدالة `diffprivlib.tools.mean`. درسنا حالتين: ساعة واحدة (19:00) بميزانية ε، وملف 24 ساعة كاملاً تُقسَّم فيه الميزانية إلى $\varepsilon/24$ لكل ساعة (التركيب المتتالي). كررنا كل تجربة 300 مرة وقسنا الخطأ المطلق بالنسبة إلى المتوسط بعد القصّ، وهو ما تحسبه الآلية فعلاً.

ε	MAE ساعة واحدة (تنفيذنا)	diffprivlib	النظرية $U/(n\varepsilon)$	خطأ نسبي	MAE ملف 24 ساعة	خطأ نسبي (24 ساعة)
0.1	30.07	30.87	31.95	%9.0	763.2	%275
1	3.07	2.96	3.19	%0.92	77.4	%27.9
10	0.29	0.35	0.32	%0.09	7.6	%2.7

جدول 4 — الخطأ (kWh) بدلالة ε. القيم المقيسة تطابق القيمة النظرية $E|\mathrm{Lap}(b)| = b$.



شكل 2 — الخطأ بدلالة ε (مقياس لوغاريتمي): الخطأ $\propto 1/\varepsilon$، وملف 24 ساعة أسوأ بـ 24 مرة. الخط الأحمر تحيّز القصّ، وهو لا يتغيّر مع ε.

أثر الحد U. البيانات شديدة الالتواء (عميل واحد يصل إلى 78 000 kWh في الساعة)، فيتجاوز 41 عميلاً الحد U عند الساعة 19:00، وينتج عن القصّ **تحيّز قدره 520 kWh** (61% من المتوسط الحقيقي 852 kWh)، وهو أكبر من ضجيج Laplace عند أي ε في دراستنا. رفع U إلى 5000 kWh يخفض التحيّز إلى 327 kWh لكنه يرفع الضجيج المتوقع عند $\varepsilon = 1$ من 3.19 إلى 15.97 kWh (الملف `dp_bound_study.csv`). الخلاصة: في بيانات IoT غير المتجانسة، **اختيار الحد أو تقسيم السكان (مثلاً حسب شريحة التعريفة) أهم من اختيار ε**. أما القيم السالبة الظاهرة عند $\varepsilon = 0.1$ فتُصحَّح بمعالجة لاحقة (قصّ إلى الصفر) دون أي كلفة على الخصوصية.

2. الجزء B — الهوية ذاتية السيادة (SSI)

2.1 الأدوار والمعرّفات اللامركزية

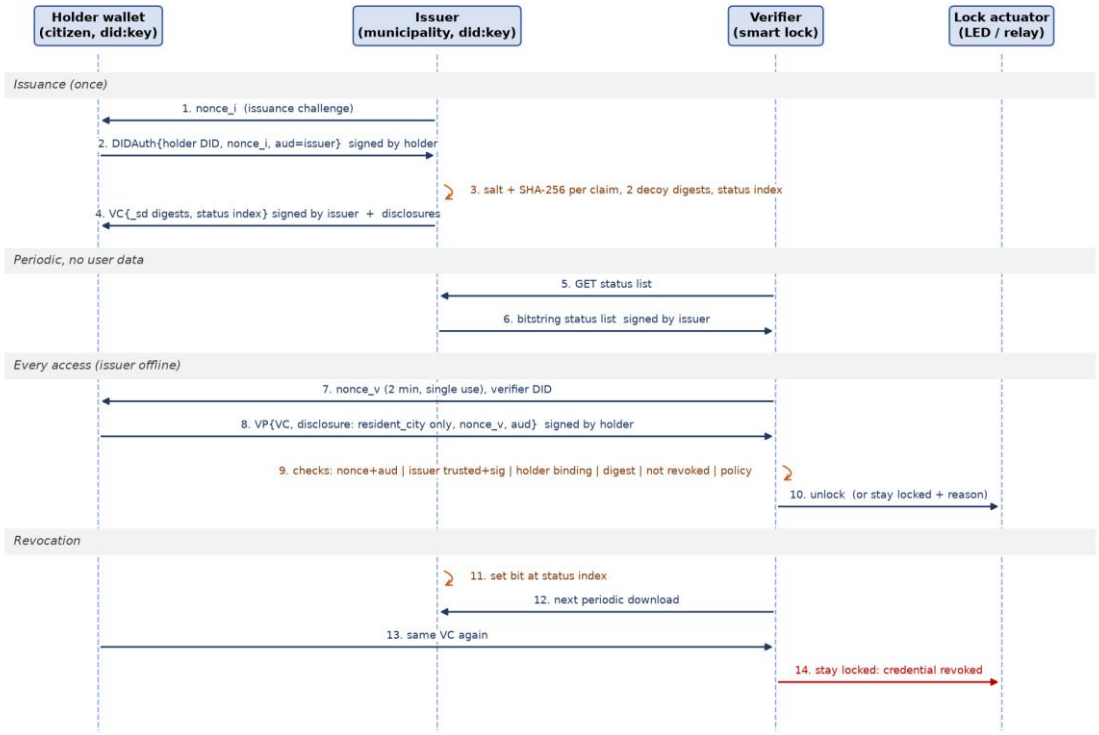
ثلاثة أدوار: **المُصدِر** (بلدية الوادي)، و**الحامل** (محفظة المواطن على حاسوب أو Raspberry Pi)، و**المتحقّق** (قفل ذكي يشترط الإقامة، وخدمة ثانية تشترط السن ≥ 18). لكل طرف معرّف **did:key** مبني على مفتاح Ed25519: `did:key:z` + base58btc(0xed01 ‖ المفتاح العام). المعرّف هو المفتاح العام نفسه، فاستخراج المفتاح منه عملية محلية لا تحتاج سلسلة كتل ولا خادماً، وهذا ما يسمح بالتحقق دون اتصال (offline). يُنتج البرنامج وثائق DID في `results/part_b`.

2.2 الإصدار والإفصاح الانتقائي

قبل الإصدار يثبت الحامل امتلاكه للـ DID بتوقيع nonce يرسله المُصدِر (DID-Auth). لكل صفة يولّد المُصدِر **ملحاً عشوائياً من 128 بت** ويحسب disclosure = base64url(JSON[salt, name, value]) ثم digest = SHA-256(disclosure)، وهي فكرة SD-JWT. لا تحتوي الشهادة الموقّعة أي قيمة، بل قائمة الـ digests مرتّبة، ومعها **digest وهميان** يخفيان عدد الصفات، ورقم موقع عشوائي في قائمة الإلغاء. يوقّع المُصدِر الشهادة بـ Ed25519 على JSON مرتّب المفاتيح، ويتحقق الحامل من كل شيء قبل تخزينها. الملح ضروري: بدونه يكفي تجريب القيمتين true و false لكسر digest الصفة `over_18`.

2.3 التقديم والتحقق دون الاتصال بالمُصدِر

يرسل القفل nonce صالحاً دقيقتين ولمرة واحدة. يقدّم الحامل الشهادة مع الإفصاحات التي اختارها فقط، ومعها الـ nonce ومعرّف القفل (audience)، ويوقّع كل ذلك بمفتاحه. يفحص القفل بالترتيب: (1) الـ nonce جديد وغير مستعمل والـ audience هو نفسه، (2) المُصدِر ضمن قائمة الثقة وتوقيعه صحيح وتاريخ الصلاحية ساري، (3) الموقّع هو صاحب الشهادة `credentialSubject.id` (ربط بالحامل)، (4) كل إفصاح يطابق digest موقّعاً، (5) قائمة الإلغاء المخزّنة حديثة (≤ ساعة) والبت المقابل غير مفعّل، (6) الصفات المكشوفة تحقق السياسة. لا يتصل القفل بالبلدية أثناء هذه الخطوات (الشكل 3).



شكل 3 — مخطط تتابع تبادل الشهادة: الإصدار، تحميل قائمة الإلغاء، التقديم والتحقق، ثم الإلغاء (المصدر: `docs/sequence_diagram.md` و `part_b/sequence_diagram.py`).

2.4 الإلغاء

قائمة إلغاء على شكل سلسلة بتات من 131 072 بت (فكرة W3C Bitstring Status List)، مضغوطة وموقّعة من المُصدِر. لكل شهادة موقع عشوائي فيها. يحمّل المتحقّق القائمة دورياً دون أي معلومة عن المستخدم، فلا يعرف المُصدِر أي شهادة يجري فحصها (خصوصية القطيع). إذا كانت القائمة غائبة أو أقدم من ساعة يرفض القفل (fail closed).

السيناريو	النتيجة	السبب / ما تعلّمه المتحقّق
القفل يطلب الإقامة	✓ قبول	يتعلّم resident_city = El Oued فقط
الخدمة تطلب السن	✓ قبول	يتعلّم over_18 = true، وتاريخ الميلاد يبقى مخفياً
إعادة إرسال تقديم ملتقط	✗ رفض	nonce مستعمل (replay)
الحامل يخترع إفصاحاً بملح جديد	✗ رفض	digest غير موقّع من المُصدِر
شهادة مسروقة يقدّمها حامل آخر	✗ رفض	المقدِّم ليس صاحب الشهادة
السارق ينتحل DID الضحية	✗ رفض	توقيع الحامل غير صالح

السيناريو	النتيجة	السبب / ما تعلّمه المتحقّق
شهادة من مُصدِر مزيّف	رفض ✗	المُصدِر خارج قائمة الثقة
كشف given_name فقط للقفل	رفض ✗	الصفة المطلوبة غير مكشوفة
تقديم مُعدّ لمتحقّق آخر	رفض ✗	audience خاطئ
بعد الإلغاء وقبل تحديث القائمة	قبول (مقصود)	نافذة التقادم: القائمة المخزّنة قديمة
بعد تحديث قائمة الإلغاء	رفض ✗	الشهادة ملغاة
قائمة إلغاء عمرها ساعتان	رفض ✗	fail closed

جدول 5 — نتائج `python -m part_b.demo`: الـ 12 سيناريو كلها مطابقة للمتوقع، وتغطيها أيضاً الاختبارات الآلية الـ 20 في `tests/test_ssi.py`.

2.5 مقارنة مع تسجيل الدخول المركزي OAuth 2.0 / OpenID Connect

أعدنا الأسبوع نفسه بالنظامين (`part_b/oauth_comparison.py`): فتح القفل يومياً، وزيارتان للخدمة ذات السن، وزيارة للصيدلية.

	OAuth 2.0 / OIDC (مزوّد مركزي)	SSI (عملنا)
ما يعرفه مزوّد الهوية / المُصدِر	10 أحداث دخول: من، وأين، ومتى	حدث واحد: الإصدار
ما يتلقاه القفل	sub، الاسم، تاريخ الميلاد، العنوان	resident_city فقط
ما تتلقاه خدمة السن	sub، الاسم، تاريخ الميلاد	over_18 فقط
الاتصال بالمزوّد عند كل دخول	ضروري	غير ضروري (offline)
أين تقع الثقة	في المزوّد: نقطة فشل وتتبّع واحدة	في مفتاح المُصدِر وفي حماية الحامل لمفتاحه

جدول 6 — من يعرف ماذا. الـ scopes في OAuth هي ما يطلبه تكامل نموذجي، وتقليصها لا يمنع المزوّد من رؤية كل عملية دخول.

3. نقاش أمني وحدود العمل

- **k-anonymity مقابل DP:** الأولى تنشر سجلات قابلة للتحليل، لكن ضمانها نحوي ولا يصمد أمام المعرفة المسبقة ولا التجانس. الثانية تعطي ضماناً رياضياً لا يرتبط بما يعرفه المهاجم، لكنها لا تنشر سجلات، وميزانيتها تُستهلك مع كل استعلام (24 استعلاماً = ε/24 لكل منها).
- **أشباه المعرّفات مركّبة:** نسبة 47.9% تتبع التوزيع الذي ولّدناه. ما يثبته العمل هو الآلية، لا الرقم بالضبط.
- **قابلية الربط في SSI:** الإفصاح بالـ hash يكشف التوقيع نفسه ومعرّف الشهادة ومعرّف الحامل في كل تقديم، فيمكن لمتحقّقين متواطئين ربط زياراته. الحل: توقيعات BBS+ (إثبات بلا معرفة) أو DID مختلف لكل علاقة.
- **الإلغاء والتوفّر:** نافذة الإلغاء تساوي مدة تحديث القائمة. سياسة fail closed تمنع قبول شهادة ملغاة، لكنها قد تُبقي الباب مغلقاً عند انقطاع الشبكة، وهي مفاضلة يجب حسمها لكل جهاز.
- **المفاتيح:** في العرض تبقى المفاتيح في الذاكرة فقط. في جهاز حقيقي يجب حفظها في عنصر آمن أو TPM، مع آلية استرداد، لأن ضياع المفتاح يعني ضياع الهوية.
- **تبسيطات معلنة:** صيغة التوقيع (JSON مرتّب المفاتيح + Ed25519) غير مسجّلة كمعيار. الشهادة على شكل W3C VC 2.0 دون شهادة توافق. التحقق من هوية المواطن الحقيقية قبل الإصدار خارج البروتوكول.

4. ما بنيناه وما أعدنا استخدامه

من بنائنا	معاد استخدامه
البيانات الديموغرافية المركّبة، السجل العام، جدول الحقيقة، هجوم الربط وتقييمه	بيانات UCI / Monash الحقيقية، pandas
هرم التعميم، البحث الشامل في الشبكة مع الحذف، مقاييس NCP و DM	pycanon (تحقق مستقل من k و l)
آلية Laplace للمتوسط المحدود، تقسيم الميزانية، دراسة الخطأ والحد U	matplotlib (للمقارنة)، diffprivlib
did:key و base58btc، التوقيع على JSON، الإفصاح الانتقائي مع الـ digests الوهمية، DID-Auth، ربط الحامل، nonce و audience، قائمة الإلغاء، الأدوار الثلاثة، مقارنة OAuth	مكتبة cryptography (Ed25519، SHA-256)

إعادة الإنتاج (التفاصيل في README). يحمّل الأمر الأول البيانات (11.8 MB) ويتحقق من بصمتها MD5، والبذرة 2026 تجعل نتائج الجزء A ثابتة في كل تشغيل:

```
python -m part_a.run_all
python -m part_b.demo   |   python -m part_b.oauth_comparison
python -m pytest -q        # 26 passed
```

المراجع: Sweeney, k-anonymity (2002) · Dwork & Roth, The Algorithmic Foundations of Differential Privacy (2014) · W3C Verifiable Credentials Data Model 2.0 · W3C did:key Method · IETF SD-JWT · W3C Bitstring Status List · Godahewa et al., Monash Time Series Archive (Zenodo 4656140).